

INTERACTIVE SECURITY GUIDE

AuthLab Learner Workbook

Passwords · phishing · MFA · passkeys

The screenshot shows the AuthLab Learner Workbook interface. At the top, there's a dark navigation bar with 'A/ AuthLab' on the left and 'Learn Passwords Phishing Passkeys Results' in the center. A 'Device-local - v2.0.0' button is on the right. The main content area has a light beige background. On the left, a large '01' is next to the title 'IDENTITY ENGINEERING · LO-01'. The main title is 'A login is three decisions, not one'. Below it, a subtitle reads: 'Explore the layers, then complete the checkpoint. Opening the module alone does not count as completion.' The content is divided into three columns: 'THE ACCOUNT CLAIM' (Identity), 'THE ACCEPTED PROOF' (Authentication), and 'THE PERMITTED ACTION' (Authorisation). Each column has a brief description. At the bottom, a question asks: 'A valid learner signs in but can delete every course. Which layer failed?' with two input boxes labeled 'identity' and 'authentication'.

THE ACCOUNT CLAIM	THE ACCEPTED PROOF	THE PERMITTED ACTION
Identity A record says Alex is linked to account 1042.	Authentication Alex demonstrates control of an approved authenticator.	Authorisation Policy lets account 1042 read one course—not the admin console.

A valid learner signs in but can delete every course. Which layer failed?

identity	authentication
----------	----------------

Course COMP6441 Security Engineering

Student Name: _____ zID: _____

Audience Beginners; no prior security or programming knowledge required

Prepared 20 July 2026

Safety and privacy

Use only fictional examples. Never enter or disclose a real password, OTP, recovery answer, account identifier or biometric. The website stores progress on this device and asks for no name or email.

Participant information and activity plan

Participant code (do not write your name): _____ Activity version: 2.0.0

Complete Form A before the modules. The website records answers but does not reveal correctness until Form B. Complete four explicit checkpoints, then Form B, confidence and optional feedback. Export only if you freely agree to share a de-identified learning record with the facilitator.

Learning objectives

- LO-01: Separate identity, authentication and authorisation.
- LO-02: Trace how a reused password creates cross-service risk.
- LO-03: Use verifier/domain evidence and a trusted route.
- LO-04: Separate replay resistance from phishing resistance.
- LO-05: Explain public/private-key responsibilities.
- LO-06: Explain RP binding and residual passkey risk.

Consent check

☐ I have read the information; I understand participation is voluntary; I will use no real credentials; I may stop; and I choose whether to share an export. Signature/initial (if required): _____

Form A • Pre-test

Answer before opening the modules. Record subjective confidence after the six items. Do not seek the answer key.

A-01. Authentication primarily answers which question?

- ☐ A. What actions are permitted?
- ☐ B. Can the claimant prove control of an accepted authenticator?
- ☐ C. Which records should be archived?

A-02. Why can one leaked password compromise another service?

- ☐ A. Reuse lets an attacker replay the same proof
- ☐ B. Browsers automatically copy databases
- ☐ C. Encryption stops after a breach

A-03. Which evidence most directly identifies the verifier for a web sign-in?

- ☐ A. The logo
- ☐ B. The registered domain/origin
- ☐ C. The colour scheme

A-04. Why can a short-lived TOTP still be phished?

- ☐ A. It may be relayed to the real service before expiry
- ☐ B. It always contains the password
- ☐ C. It is a public key

A-05. What does a passkey relying party normally store?

- ☐ A. The private key
- ☐ B. Public-key material and credential metadata
- ☐ C. A biometric image

A-06. What provides WebAuthn's phishing resistance?

- ☐ A. Longer usernames
- ☐ B. Verifier-name/RP-ID binding in the ceremony
- ☐ C. A hidden button

Subjective confidence

Before the modules, how confident are you that you can explain your answers? 1 2 3 4 5

Module 1 • Three decisions

Layer	Question	Example
Identity	Which account is claimed?	Alex is linked to account 1042.
Authentication	What proof is accepted now?	Control of an approved authenticator.
Authorisation	What action may the session perform?	Read one course, not delete all courses.

Checkpoint: A valid learner signs in but can delete every course. Which layer failed, and why?

Answer: _____

Reason: _____

A/ AuthLab

LearnPasswordsPhishingPasskeysResults

Device-local - v2.0.0

01

IDENTITY ENGINEERING - LO-01

A login is three decisions, not one

Explore the layers, then complete the checkpoint. Opening the module alone does not count as completion.

THE ACCOUNT CLAIM

Identity

A record says Alex is linked to account 1042.

THE ACCEPTED PROOF

Authentication

Alex demonstrates control of an approved authenticator.

THE PERMITTED ACTION

Authorisation

Policy lets account 1042 read one course—not the admin console.

A valid learner signs in but can delete every course. Which layer failed?

identity

authentication

Use the website interaction, then record your reasoning here.

Module 2 • Credential stuffing

Run only the website's fixed fictional simulation. Trace the path: one exposed credential → automated trials → cross-service acceptance or rejection → account impact.

Stage	What changed the outcome?	Residual risk
Exposure	_____	_____
Automated replay	_____	_____
Cross-service acceptance	_____	_____

Checkpoint: Why is 'make the password more complex' incomplete? _____

One password control: _____ One system control: _____

Module 3 • Phishing and impersonation

For each fictional scenario, record the registered domain or trusted route before deciding. A polished page and familiar sender name are not proof of verifier identity.

Scenario	Decisive evidence	Decision / safer route
PH-01 Security-key registration	_____	_____
PH-02 Mailbox urgency	_____	_____
PH-03 Shared-document consent	_____	_____
PH-04 MFA expiry	_____	_____

Checkpoint: Why is 'the logo looks right' weak evidence? _____

Module 4 • MFA and passkeys

Threat assumptions: the attacker has a leaked password and may relay credentials through a real-time phishing site. Device compromise and recovery are analysed as residual risks.

Mechanism	Replay resistance	Phishing resistance	One reason
Password only	No	No	Reusable shared proof
Password + SMS	Limited	No	Live relay / telecom risk
Password + TOTP	Short-lived	No	Live relay before expiry
Password + push	Often	Not inherent	Fatigue / weak context
Passkey/WebAuthn	Yes	Yes	Fresh challenge + RP binding

Conceptual ceremony

1. The relying party issues a fresh challenge through the browser.
2. The browser/authenticator scopes the operation to the relying party.
3. The authenticator performs local presence or verification according to policy.
4. The authenticator signs; private-key material is not sent to the relying party.
5. A production server verifies challenge, origin/RP binding, flags and signature.

Checkpoint: A passkey resists a look-alike origin because _____

One risk reduced: _____ One risk remaining: _____

Form B • Post-test

Complete without looking back at Form A. The concepts are matched but the scenarios and wording differ.

B-01. A valid user signs in but can delete every account. Which layer failed?

- ☐ A. Identity
- ☐ B. Authentication
- ☐ C. Authorisation

B-02. After Service A is breached, what makes reuse dangerous at Service B?

- ☐ A. The same replayable proof may be accepted
- ☐ B. Every browser shares cookies
- ☐ C. Password length becomes zero

B-03. A page perfectly copies a bank's design. What evidence still matters most?

- ☐ A. Registered domain/origin and a trusted route
- ☐ B. Logo size
- ☐ C. Background colour

B-04. Which statement about TOTP is most accurate?

- ☐ A. It cannot be phished
- ☐ B. It can be relayed before it expires
- ☐ C. It is an asymmetric key

B-05. Where should passkey private-key material remain protected?

- ☐ A. With the authenticator/platform
- ☐ B. In an email
- ☐ C. In the URL

B-06. What does verifier-name binding achieve?

- ☐ A. It binds output to the intended relying party
- ☐ B. It hides the username font
- ☐ C. It forces monthly password changes

Subjective confidence

After the modules, how confident are you that you can explain your answers? 1 2 3 4 5

Reflection and optional feedback

The distinction I can now explain most clearly is ...

A decision I changed after inspecting the evidence was ...

One idea that remains confusing is ...

One project limitation I noticed is ...

One improvement I recommend is ...

Usefulness rating: 1 2 3 4 5 I choose to share a de-identified export: ☐ Yes ☐ No

Before sharing

Do not type personal information in feedback. An export is de-identified, not guaranteed anonymous; the file may still reveal context when combined with external information.